SciLifeLab

Deploying AI Agents

Legal, Technical, and Practical Considerations

Johan Alfredéen, SciLifeLab Data Centre
Mahbub Ul Alam, SciLifeLab Data Centre
Dinh Long Huynh, Uppsala university

March 5, 2026

Building, Deploying & Using AI Agents

Topics

- ❑ Legal
- ❑ Quality
- ❑ Deployment
- ❑ Security

SciLifeLab AI Strategy

MARCH 3, 2026

SciLifeLab publishes new AI Strategy to support researchers nationwide

Pillar #4

AI Tools & Technology Watch – Deliver user-friendly AI tools such as foundation models, **agents**, and MLOps, while continuously monitoring global AI

Legal and policy considerations

GDPR

EU AI Act

National and University policies

Others

The need for regulation

<u>Ethical challenges of AI systems</u>

- Fairness and bias
- Transparency
- Privacy
- Accountability

The need for regulation

For example Fairness, Bias and Transparency

For example, it is often not possible to find out why an AI system has made a decision or prediction and taken a particular action. So, it may become difficult to assess whether someone has been unfairly disadvantaged, such as in a hiring decision or in an application for a public benefit scheme.

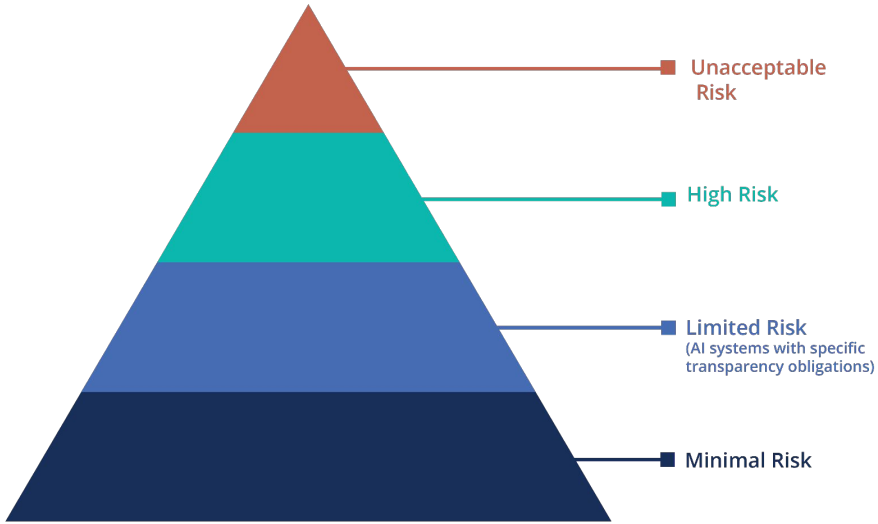
European Commission, "AI Act", accessed October 27, 2025, https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai

EU AI Act: Scope and actors

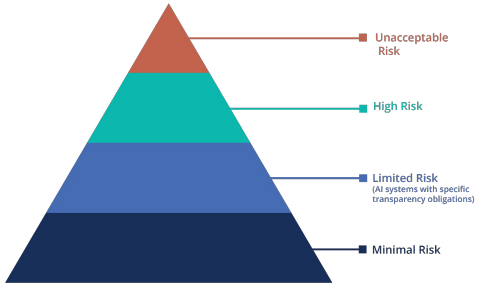
(a) **providers** *placing on the market* or *putting into service* **AI systems** or placing on the market **general-purpose AI models**

(b) **deployers** of **AI systems**

EU AI Act : Risk levels



EU AI Act : Risk levels, examples



Unacceptable (Prohibited) AI systems

- Social scoring, facial recognition, manipulation

High risk

- Serious risks to health, safety or fundamental rights: Profiling individuals' work performance or location or movement; Safety components in the management and operation of critical digital infrastructure

Limited risk

- Chatbots, certain AI-generated content

Minimal risk (unregulated)

- AI-enabled video games, spam filters

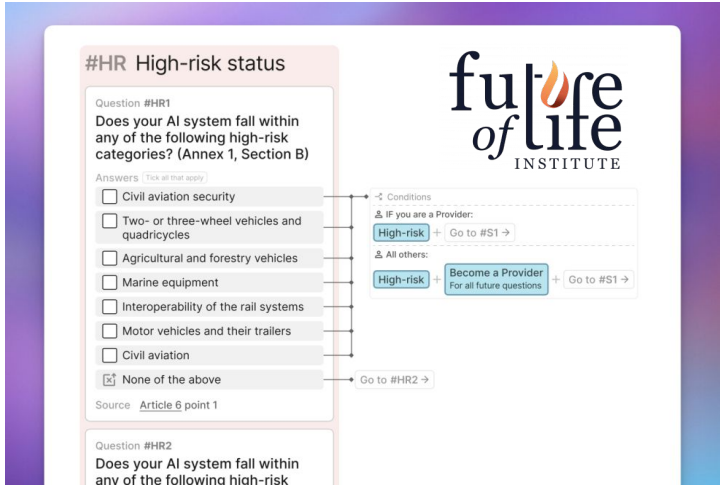
EU AI Act : Common obligations

Transparency obligation (human and machine)

AI Literacy obligation

Register the AI-system

EU AI Act : Compliance



Does the EU AI Act apply?

The Compliance Checker / self-assessment tool

https://artificialintelligenceact.eu/assessment/eu-ai-act-compliance-checker/

EU AI Act : An example

Scenario: Create and deploy an AI Agent for use in education and training in molecular biology.

Transparency obligations: Interacting directly with users

You need to follow these transparency obligations under Article 50, point 1:

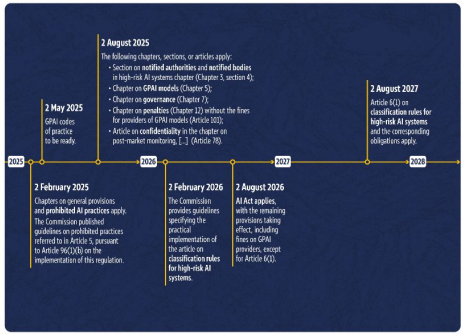
- Ensure that AI systems intended to interact directly with people are designed and developed so that users are informed that they are interacting with an AI system.

This does not apply to uses permitted by law to detect, prevent or investigate criminal offences.

AI Literacy obligations

You must take measures to ensure a sufficient level of AI literacy for your staff (and other people dealing with the operation and use of AI systems on their behalf), taking into account their technical knowledge, experience, education and training and the context the AI systems are to be used in, according to Article 4.

EU AI Act Key points and timeline



Rolled out in phases 2024 - 2027

- Published July 2024
- General-purpose AI models (e.g., LLMs) face transparency and compliance rules starting 2025.
- **August 2026: Deadline for high-risk AI systems (e.g., in healthcare, law enforcement, critical infrastructure) to fully comply with the AI Act.**

Whistleblowing

The EU AI Act and the Whistleblowing Directive

For reporting violations of the EU AI Act

Protection against retaliation

AI Policies and Guidelines

University AI policies

- UU AI policy: *Guidelines on the use of generative AI in teaching and assessment*
- Department AI policies (“local provisions which may be more detailed and/or restrictive”)

National policies and guidelines

- Government agencies, Riktlinjer för generativ AI inom offentlig förvaltning, DIGG (Guidelines for Generative AI in Govt Agencies)
- AI Sweden’s Riktlinjer för ansvarsfull AI (Guidelines for Responsible AI)

AI policies summarised

Key points from AI Sweden's Guidelines for Responsible AI:

- People in the centre: AI should empower people and their decisions.
- Accountability: Humans always are responsible
- Trackable and understandable decisions made by AI.
- Fairness: all people treated fairly, without discrimination.

Other recommendations, UU (1):

- Always fact check
- Check copyright rules
- GDPR-related: "Never share sensitive or confidential information while using any AI tool."

1) Accessed November 7, 2025. https://www.uu.se/en/staff/service-and-tools/ai/introduction-to-ai-in-research

Sustainability

UN environment programme

9 INDUSTRY, INNOVATION AND INFRASTRUCTURE

12 RESPONSIBLE CONSUMPTION AND PRODUCTION

Problems

- Water use, often scarce resource
- Energy use, often fossil sources
- Electronic waste
- Raw materials, often destructive mining

EU AI Act

Disclose energy consumption and environmental impact.

Accessed November 12, 2025.
https://www.unep.org/news-and-stories/story/ai-has-environmental-problem-heres-what-world-can-do-about

Software Quality

Quality : LLM-backed system

News Integrity in AI Assistants

An international PSM study

study of 3000 news items

45% news articles found incorrect

significant errors in OpenAICo's ChatGPT, Microsoft's Copilot, Google's Gemini, and Perplexity

source: EBU/PSM/BBC, International study, October 2025

Confabulation

Fabrications, and factual errors. Generation of narrative details that, while incorrect, are not recognized as such.

Hallucination

An unfounded or mistaken impression or notion; responses unrelated to the input.

Problematic: very convincing falsehoods

News Integrity in AI Assistants, https://www.ebu.ch/Report/MIS-BBC/NI_AI_2025.pdf
Hallucination or Confabulation? Neuroanatomy as metaphor in Large Language Models, Accessed October 28, 2025, https://pmc.ncbi.nlm.nih.gov/articles/PMC10619792/

Software Quality

Rule of thumb:

“Designing for agents, often same as designing for humans”

Agents make many mistakes

- provide clear error messages and good hints how to fix problems
- use warnings library and warning messages

Scalability and performance

Cache commonly used queries and answers

- Can help save on AI tokens used
- Improve performance

Quality : Testing

<u>Before release, offline</u>

Testing (correctness) and Evaluation (performance,relative)

Deterministic parts: automated tests

AI-systems: automated tests validate basic functionality

- ➢ Caution: LLM-use can quickly rack up

Heuristics

LLM-as-a-Judge. Small LM as judge (but risk of overfitting on small “golden dataset”)

<u>After release, online</u>

From user feedback

Online evaluation

Security Challenges

Security challenges

Paper *Systematic Analysis of MCP Security, 2025*

New vulnerability types

MCP-based agents broaden the attack surface and simplify exploitation

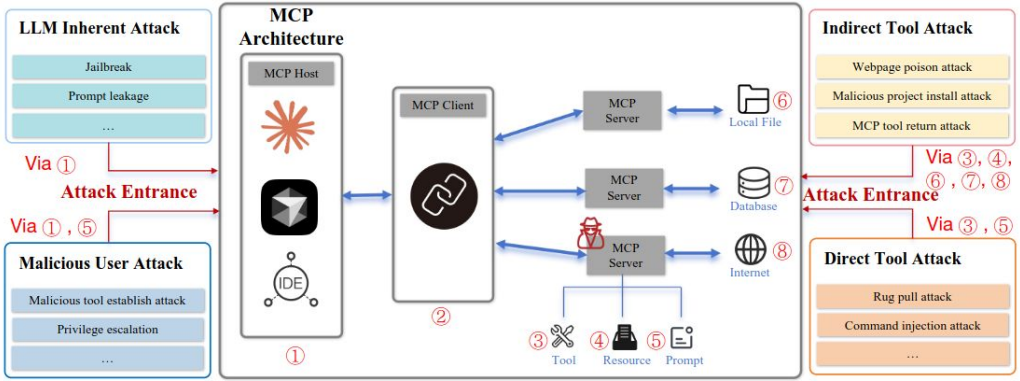
Common attack vectors:

- prompt injection
- broad authorization

Systematic Analysis of MCP Security, 2025, arXiv:2508.12538, https://doi.org/10.48550/arXiv.2508.12538

Security challenges

Paper *Systematic Analysis of MCP Security, 2025*



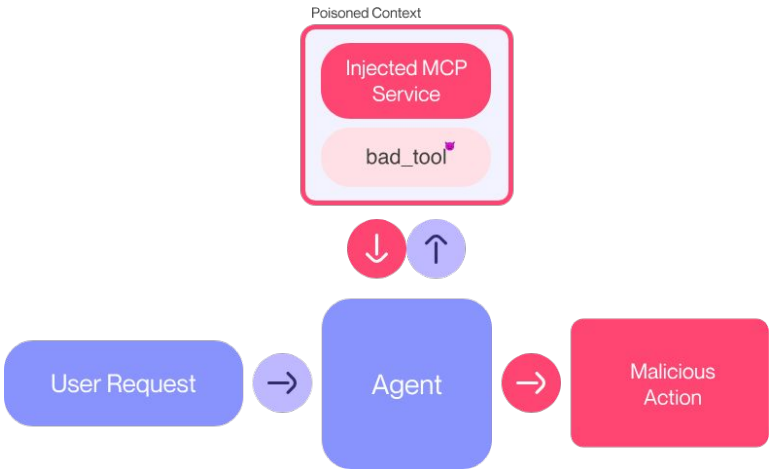
MCP Attack Library (MCPLIB), which categorizes and implements 31 distinct attack methods.

Four key categories

1. direct tool injection
2. indirect tool injection
3. malicious user attacks
4. LLM inherent attacks

Systematic Analysis of MCP Security, 2025, arXiv:2508.12538, https://doi.org/10.48550/arXiv.2508.12538

Vulnerability : Tool Poisoning Attacks (TPA)



Security company Invariant Labs

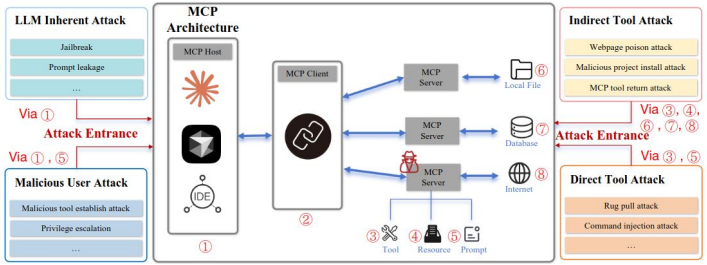
Malicious instructions in MCP **tool descriptions** that are invisible to users but visible to AI models.

Risks:

- sensitive data exfiltration
- unauthorized actions by AI models

MCP Security Notification: Tool Poisoning Attacks, https://invariantlabs.ai/blog/mcp-security-notification-tool-poisoning-attacks

Security : MCP Registries



Information Regarding Malicious "postmark-mcp" Package

Postmark team

SHARE

We recently became aware of a malicious npm package called "postmark-mcp" on npm that was impersonating Postmark and stealing user emails. **We want to be crystal clear: Postmark had absolutely nothing to do with this package or the malicious activity.**

Here's what happened: A malicious actor created a fake package on npm impersonating our name, built trust over 15 versions, then added a backdoor in version 1.0.16 that secretly BCC'd emails to an external server.

What you should know:

- **This is not an official Postmark tool.** We have not published our Postmark MCP server on npm prior to this incident
- **We didn't develop, authorize, or have any involvement** with the "postmark-mcp" npm package
- **The legitimate Postmark API and services remain secure** and unaffected by this incident

Publicly available, locally executed MCPs (coding tools, etc)

Be very skeptical using other MCP servers and tools

MCP tools, what you see is name, description - not implementation

Avoid third-party MCP servers and MCP registries

Only use MCP servers trust!

Systematic Analysis of MCP Security, 2025, arXiv:2508.12538, https://doi.org/10.48550/arXiv.2508.12538

MCP Security scanning tool

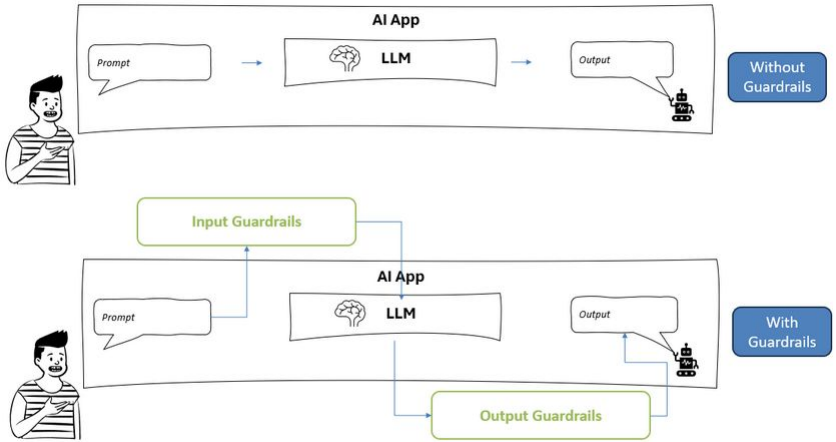
Introduced in paper *MCP Safety Audit: LLMs with the Model Context Protocol Allow Major Security Exploits, 2025*

MCPSafetyScanner

We show that industry-leading LLMs may be coerced to use MCP tools and compromise an AI developer's system through a wide range of attacks, e.g., malicious code execution, remote access control, and credential theft.

https://arxiv.org/abs/2504.03767

AI Guardrails



Apply strict guardrails limiting the AI Agent

- Ex: disallow certain commands
- Allow only certain actions (whitelist)

“Guardrails AI” framework, open source: https://github.com/guardrails-ai/guardrails

Operations and maintenance

Observability

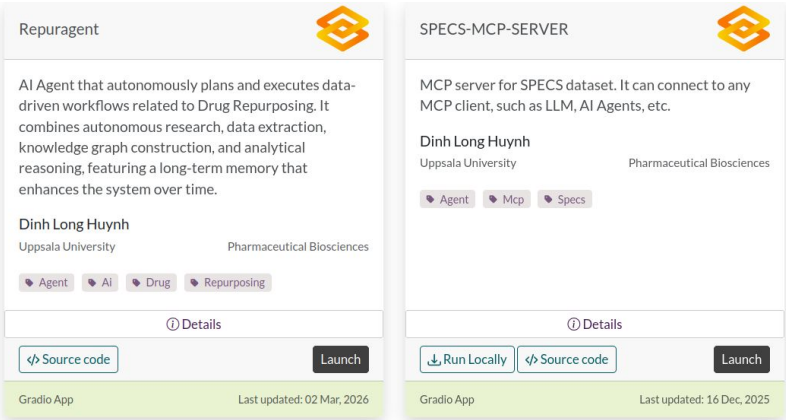
Monitoring and logging

- Audit: who (end user) does what
- Log steps taken by AI Agent -> trackable records
- Technical logs
- Performance metrics

User feedback

- Continual improvement

SciLifeLab Serve



A platform offering machine learning model serving, app hosting, web-based integrated development environments, and other tools **to life science researchers affiliated with a Swedish research institute**.

https://serve.scilifelab.se/

Suitable uses of LLM-backed systems

Think about the functionalities of the system

- “AI-things, LLM-things” vs “non-AI things, non-LLM things”

When NOT to use LLMs. Consider these tasks

- Calculations (e.g. coordinate conversion)
- Algorithms with optimal solutions/implementations
- Saving files
- Database queries
- etc

Use the deterministic implementation

- “MCP tools” in an AI-system

Feedback Request

We'd appreciate your **input and observations** from the hands-on

What **use cases** do you see for Agentic AI tools for your own life science research?

What **tools and services** could SciLifeLab Data Centre provide?

Thoughts on **hosting or integration within the SciLifeLab Data Centre**?

Thank you for listening!

We'd love to hear from you!

If you have any questions or feedback, please email us at datacentre@scilifelab.se
or
serve@scilifelab.se

SciLifeLab

Thank you for listening!

Feedback and Questions

AI Network (SciLifeLab) - Slack channel #ai-network
Website https://www.scilifelab.se/data-ai/